

Day 11: IAM and Networking Infrastructure

This module focuses on the dual pillars of Google Cloud security: Identity and Access Management (IAM) and Virtual Private Cloud (VPC) networking. Mastering these ensures that your workloads are not only reachable but are also operating under the principle of least privilege.

Section 1: Cloud IAM and Security Foundations

Identity and Access Management (IAM) provides the framework for "Who" can do "What" on "Which" resource.

1.1 IAM Concepts and Best Practices

- **The IAM Policy:** A collection of statements that define access. It attaches a **Member** (identity) to a **Role** (permissions) at a specific **Resource** level.
- **Best Practice: Least Privilege:** Always grant the minimum permissions required for a task.
- **Best Practice: Resource Hierarchy:** Inherit permissions from Organization > Folder > Project > Resource. Avoid granting broad permissions at the Project level if only a single Bucket is needed.

1.2 Roles: Primitive, Predefined, and Custom

Role Type	Description	Use Case
Primitive	Owner, Editor, Viewer. Highly broad.	Development environments only; never production.
Predefined	Managed by Google; specific to services (e.g., roles/pubsub.publisher).	Recommended for most enterprise scenarios.
Custom	User-defined list of specific permissions.	Used when predefined roles grant more access than desired.

1.3 Service Accounts and Workload Identity

- **Service Accounts:** Identities used by applications rather than humans. They use RSA keys or automated tokens for authentication.
 - **Workload Identity:** The recommended method for GKE. It links a Kubernetes Service Account (KSA) to a Google Service Account (GSA), eliminating the need for manual JSON key management.
-

Section 2: GCP Networking Fundamentals

A VPC is a global, software-defined network that provides connectivity for your cloud resources.

2.1 VPC Architecture and Subnets

- **Global Scope:** Unlike other cloud providers, a GCP VPC is global. Subnets, however, are regional.
- **Isolation:** VPCs provide logical isolation. Traffic between VPCs requires VPC Peering or Cloud VPN.

2.2 IP Addressing Strategies

- **Primary IP Ranges:** These addresses are used for the virtual machine instances (nodes) themselves.
 - **Secondary IP Ranges:** Essential for containerized environments. In GKE, these ranges are used for **Alias IPs**, allowing Pods and Services to have their own unique IP space separate from the nodes.
-

Section 3: Case Studies and Scenarios

Case Study: Financial Microservices Isolation

Problem: A banking application requires strict compliance. The Frontend must talk to the Backend, but the Frontend must never have direct access to the Database.

Solution:

1. **Networking:** Place the Database in a restricted subnet with no external IP. Use Firewall rules to allow ingress only from the Backend's specific IP range.
2. **IAM:** Create a unique Service Account for the Backend. Grant it roles/cloudsql.client, but do not grant this role to the Frontend Service Account.

Case Scenario: Multi-Tenant GKE Cluster

Requirement: Host two different departments (HR and Finance) on the same GKE cluster while ensuring Finance cannot access HR's Cloud Storage buckets.

Solution: Implement **Workload Identity**. Map the hr-namespace KSA to an hr-gsa service account, and the fin-namespace KSA to a fin-gsa service account. Apply IAM policies to the buckets specifically for these GSAs.

Section 4: Mini Project - Secure Infrastructure Deployment

This lab demonstrates how to provision a secure network and assign identities to a Cloud Run service.

Part A: Networking Infrastructure

Execute these commands to establish a custom-mode network with secondary ranges.

Bash

```
# Create a custom VPC network
```

```
gcloud compute networks create enterprise-vpc --subnet-mode=custom
```

```
# Create a regional subnet with secondary ranges for Pods and Services
```

```
gcloud compute networks subnets create gke-regional-subnet \
```

```
--network=enterprise-vpc \
```

```
--range=10.10.0.0/24 \
```

```
--region=us-east1 \
```

```
--secondary-range=pods=172.16.0.0/20,services=172.16.16.0/24
```

Part B: IAM and Workload Security

Provision a service account for a Cloud Run workload and assign minimal permissions to read from a specific bucket.

Bash

```
# 1. Create a dedicated Service Account
```

```
gcloud iam service-accounts create cloud-run-app-sa \
```

```
--display-name="App Engine/Cloud Run Identity"
```

```
# 2. Grant Storage Object Viewer permission at the Bucket level (not Project level)
```

```
gcloud storage buckets add-iam-policy-binding gs://your-app-data-bucket \
```

```
--member="serviceAccount:cloud-run-app-sa@[PROJECT_ID].iam.gserviceaccount.com"
\  
--role="roles/storage.objectViewer"
```

3. Deploy a Cloud Run service using this identity

```
gcloud run deploy private-service \  
--image=gcr.io/[PROJECT_ID]/app-image \  
--service-account=cloud-run-app-sa@[PROJECT_ID].iam.gserviceaccount.com \  
--region=us-east1 \  
--no-allow-unauthenticated
```

Part C: Verification

To verify the network configuration and IAM bindings, use the following commands:

- **Networking:** gcloud compute networks subnets describe gke-regional-subnet --region=us-east1
- **IAM:** gcloud projects get-iam-policy [PROJECT_ID] --flatten="bindings[].members" --format='table(bindings.role, bindings.members)'